

Jeremiah Grossman

Venture capitalist (Grossman Ventures <https://grossman.vc>), Internet protector and industry creator. Founded WhiteHat Security & Bit Discovery. BJJ Black Belt.

MONDAY, JANUARY 26, 2009

Calling all Researchers! Send in the Top Web Hacking Techniques of 2008

It's time once again to create the Top Ten Web Hacking Techniques of the past year. Every year Web security produces a plethora of new and extremely clever hacking techniques (loosely defined, not specific incidents), many of which are published in hard to find locations. 2008 was no different. As we've done for the past [two years](#), we're looking for the best of the best. This effort serves as a way to create a centralized community reference and recognize those exceptional researchers who have contributed to our collective knowledge.



This year is special, because the researcher who places #1 will not only receive praise amongst his peers, but also receive one free pass to attend the [BlackHat USA Briefings 2009](#)! Over \$1,000 (US) value. Generously sponsored by BlackHat. Winners will be chosen by a panel of judges (Rich Mogull, Chris Hoff, HD Moore, Jeff Forristal) on the basis of novelty, impact, and pervasiveness.

We're also going to need your help. Below we're building the living list of everything found so far. If anything is missing, and we're positive there is because last year had over 80, we'd appreciate it if you could post a comment containing the link. Thank you and good luck!

The List

1. [Cross-Site Printing](#) (2007 issue)
2. [CUPS Detection](#)
3. [CSRFing the uTorrent plugin](#)
4. [Clickjacking / Videojacking](#)
5. [Bypassing URL Authentication and Authorization with HTTP Verb Tampering](#)
6. [I used to know what you watched, on YouTube \(CSRF + Crossdomain.xml\)](#)
7. [Safari Carpet Bomb](#)
8. [Flash clipboard Hijack](#)
9. [Flash Internet Explorer security model bug](#)
10. [Frame Injection Fun](#)
11. [Free MacWorld Platinum Pass? Yes in 2008!](#)
12. [Diminutive Worm, 161 byte Web Worm](#)
13. [SNMP XSS Attack \(1\)](#)
14. [Res Timing File Enumeration Without JavaScript in IE7.0](#)
15. [Stealing Basic Auth with Persistent XSS](#)
16. [Smuggling SMTP through open HTTP proxies](#)



BIO

Jeremiah Grossman brings 20+ years of experience in Computer Security and has become one of the most recognizable and world-renowned cybersecurity experts in the industry, coining several of the original hacking terms commonly used around the world today. Early in his career, Jeremiah was known as "The Hacker Yahoo" which led to his role as the company's Information Security Officer. Jeremiah founded WhiteHat Security (now Synopsis), and served as Chief of Security Strategy for SentinelOne which was the highest-valued cybersecurity IPO in history. Most recently, Jeremiah was the founder & CEO of Bit Discovery, which was acquired by Tenable in 2022. He also serves as a company advisor and board member to several tech startups. In his spare time, Jeremiah does Brazilian Jiu-Jitsu and is passionate about classic cars. He recently opened Toybox, a luxury car club in Boise, Idaho.

LINKS

[Jeremiah Grossman](#)

[Twitter](#)

[Facebook](#)

[LinkedIn](#)

[Grossman Ventures](#)

SUBSCRIBE

Posts

Comments

17. Collecting Lots of Free 'Micro-Deposits'
18. Using your browser URL history to estimate gender
19. Cross-site File Upload Attacks
20. Same Origin Bypassing Using Image Dimensions
21. HTTP Proxies Bypass Firewalls
22. Join a Religion Via CSRF
23. Cross-domain leaks of site logins via Authenticated CSS
24. JavaScript Global Namespace Pollution
25. GIFAR
26. HTML/CSS Injections - Primitive Malicious Code
27. Hacking Intranets Through Web Interfaces
28. Cookie Path Traversal
29. Racing to downgrade users to cookie-less authentication
30. MySQL and SQL Column Truncation Vulnerabilities
31. Building Subversive File Sharing With Client Side Applications
32. Firefox XML injection into parse of remote XML
33. Firefox cross-domain information theft (simple text strings, some CSV)
34. Firefox 2 and WebKit nightly cross-domain image theft
35. Browser's Ghost Busters
36. Exploiting XSS vulnerabilities on cookies
37. Breaking Google Gears' Cross-Origin Communication Model
38. Flash Parameter Injection
39. Cross Environment Hopping
40. Exploiting Logged Out XSS Vulnerabilities
41. Exploiting CSRF Protected XSS
42. ActiveX Repurposing, (1, 2)
43. Tunneling tcp over http over sql-injection
44. Arbitrary TCP over uploaded pages
45. Local DoS on CUPS to a remote exploit via specially-crafted webpage (1)
46. JavaScript Code Flow Manipulation
47. Common localhost dns misconfiguration can lead to "same site" scripting
48. Pulling system32 out over blind SQL Injection
49. Dialog Spoofing - Firefox Basic Authentication
50. Skype cross-zone scripting vulnerability
51. Safari pwns Internet Explorer
52. IE "Print Table of Links" Cross-Zone Scripting Vulnerability
53. A different Opera
54. Abusing HTML 5 Structured Client-side Storage
55. SSID Script Injection
56. DHCP Script Injection
57. File Download Injection
58. Navigation Hijacking (Frame/Tab Injection Attacks)
59. UPnP Hacking via Flash
60. Total surveillance made easy with VoIP phone
61. Social Networks Evil Twin Attacks
62. Recursive File Include DoS
63. Multi-pass filters bypass
64. Session Extending
65. Code Execution via XSS (1)
66. Redirector's hell
67. Persistent SQL Injection
68. JSON Hijacking with UTF-7
69. SQL Smuggling
70. Abusing PHP Sockets (1, 2)

Posted by [Jeremiah Grossman](#) at [7:02 PM](#)

27 comments:

Anonymous said...

Turning a local DoS vulnerability on CUPS into a remote exploit via specially-crafted webpage

This research nicely shows how combining different bugs, can allow us to turn a local crash, into a remote exploit via a specially-crafted webpage.

The three vulns in particular are (copied and pasted from original source):

"

1. CUPS allows anonymous users to add/remove RSS Subscriptions. This issue only affects CUPS <1.3.8. I later learned that this issue had been reported in the past and tracked by Apple as STR #2774. This issue is also being tracked as CVE-2008-5184
2. HTTP requests submitted to the CUPS web interface (<http://localhost:631/>) can be forged due to lack of tokenization (CSRF)
3. Exceeding the maximum # of RSS Subscriptions (100 by default) leads to a NULL pointer dereference crash. This issue is being tracked as CVE-2008-5183

"

Sources:

[original blog post](#)

[further details](#)

January 27, 2009 at 1:12 AM

[Jeremiah Grossman](#) said...



right on, that is a cool one! #45

January 27, 2009 at 8:14 AM

Anonymous said...

Same-site scripting:

<http://seclists.org/bugtraq/2008/Jan/0270.html>

localhost. record in domain pointing to 127.0.0.1 + XSS vulnerability in local application with web interface as source for cookies for this domain and the potential threat with other applications listening on local interface.

Martin Straka

January 27, 2009 at 9:28 AM

[Jeremiah Grossman](#) said...



Thanks Martin, I've added it to the list!

January 27, 2009 at 10:34 AM

[avivra](#) said...



Few of mine:

[Yet another Dialog Spoofing - Firefox Basic Authentication](#)
[Skype cross-zone scripting vulnerability](#)
[Safari pwns IE \(Blended Threat\)](#)
[IE "Print Table of Links" Vulnerability](#)
[A different Opera](#)

January 27, 2009 at 10:54 AM

Anonymous said...

Remembering 'Forgot My Password': Turning DNS Compromise Into A Generic Authentication Bypass For Most Web Frameworks And Major Properties

I'm sure everyone's sick of the DNS brouhaha, but I'd like to point out that there really weren't many systems *not* vulnerable to having their DNS polluted, thus causing their "forgotten password" emails to go to a controllable location. This attack was particularly fun on content management frameworks, because you don't just get the ability to read content: Forget the admin's password, and suddenly you get to post or modify arbitrary PHP thus allowing full remote code execution.

Whether it's more significant to get code execution on a CMS or user-level access to

MySpace/Facebook/Google/Yahoo/AIM/Hotmail /GoToMyPC from one common attack is up to the discretions of the reader.

January 27, 2009 at 1:47 PM

ameft said...



Jeremiah what about my work? Abusing HTML 5 Structured Client-side Storage:

<http://trivero.secdiscovers.com/html5whitepaper.pdf>

Do you think it's a good one for a mention?

I know, it's not fair to endorse themselves.. :)

January 27, 2009 at 3:49 PM

Jeremiah Grossman said...



@avivra, you are now added to the list. Thanks much for the contribution!

@DanK, we still love ya and would be happy to add a reference. Do you have a preferred one you'd like linked? Having trouble finding one myself.

@ameft, absolutely you can! I'm hoping more people do since its so tough to keep track. Added to the list!

January 27, 2009 at 4:09 PM

Anonymous said...

So far this is just looking like a massive pileup of vuln researcher self-fellatio. Meh.

January 27, 2009 at 4:46 PM

Anonymous said...

Pers XSS in embedded devices via evil SSID and DHCP hostname by Rafael Dominguez is quite cool stuff:

<http://usefulfor.com/security/2008/08/04/ssid-script-injection/>

<http://usefulfor.com/security/2008/08/04/dhcp-script-injection/>

January 28, 2009 at 3:27 AM

Arshan Dabirsiaghi said...



jeff's file download injection technique

January 28, 2009 at 7:49 AM

pdp said...



Ok, this is going to be a long list:

- * Navigation Hijacking (Frame/Tab Injection Attacks) - <http://www.gnucitizen.org/blog/hijacking-innocent-frames/>
- * UPnP Hacking via Flash (really hot stuff and it affects all of your home appliance including your TV if it has been bought recently) - <http://www.gnucitizen.org/blog/hacking-the-interwebs/>
- * Router Hacking Challenge (the biggest hacker challenge done so far and all of it is web stuff) - <http://www.gnucitizen.org/blog/router-hacking-challenge/>
- * Total surveillance made easy with VoIP phones (one of the best web hacks ever) - <http://www.gnucitizen.org/projects/total-surveillance-made-easy-with-voip-phones/>
- * Call Jacking: Phreaking the BT Home Hub (really cool web hack) - <http://www.gnucitizen.org/blog/call-jacking/>
- * Social Networks Evil Twin Attacks (well, maybe not so much Web oriented) - <http://www.gnucitizen.org/blog/social-networks-evil-twin-attacks/>
- * The Pownce Worm - <http://www.gnucitizen.org/blog/the-pownce-worm/>

January 28, 2009 at 9:42 AM

MustLive said...



Jeremiah!

I sent you email with my 18 researches, which I published in 2008. These researches are just a part of researches which I made last year and with time I'll publish many other my researches (which I made in 2006, 2007 and 2008 years).

Do you make a list of hacking techniques only for 2008? Because such interesting technique as Cross-Site Printing was published in December 2007 and was in Top Web Hacking Techniques of 2007 (is it needed to repeat yourself). If it'll be new version of technique, than it's other case.

P.S.

Besides, about same-site scripting which was mentioned by Martin. I already wrote about attacking (particularly by XSS) localhost aka 127.0.0.1 already in November 2006 in my article Using of vulnerabilities at local machines (<http://websecurity.com.ua/369/>). Which you can read on English (<http://www.google.com/translate?u=http://websecurity.com.ua/369/&langpair=ua%7Cen&hl=en&ie=UTF8>).

January 28, 2009 at 12:04 PM

Jeremiah Grossman said...



@Adrian, got them down at #55 and #56. Thanks much!

@Arshan, locked in at #57. Good one too, forgot about that.

@pdp, added most, but not all. Couldn't decide on a couple, but open to being convinced.

"Router Hacking Challenge", seem liked a collection of vulnerabilities, not "techniques". Didn't seem novel enough over existing research. Same reasoning behind "Call Jacking: Phreaking the BT Home Hub" and "The Pownce Worm". What should be reconsidered?

January 28, 2009 at 2:47 PM

Anonymous said...

JSON Hijacking with UTF-7.
pp.57-62 of
<http://powerofcommunity.net/poc2008/hasegawa.pptx>

January 28, 2009 at 5:08 PM

Jeremiah Grossman said...



Added, thanks!

January 28, 2009 at 6:48 PM

Anonymous said...

Winamp "NowPlaying" Unspecified Vulnerability: The Details

(<http://blog.watchfire.com/wfblog/2008/09/winamp-nowplayi.html>)

- The post discussed an attack against a desktop application (Winamp, in this case). It consisted of poisoning the metadata of mp3 files with JavaScript. When played, the poisoned mp3 files caused a script-injection into the context of an embedded browser within Winamp. Since the injected JavaScript code had some access to internal functionalities of Winamp, the attack could potentially be further extended to the "desktop world".

January 31, 2009 at 7:07 AM

Anonymous said...

[CSRF on Novell GroupWise WebAccess allows email theft and other attacks](#)

Although this vulnerability has just been published now in the year 2009, it was discovered in October 2008, thus I thought it was worth adding to the list.

By forging the request that adds a new forwarding rule, a copy of any email sent to the victim user will be sent to the attacker's inbox.

The bug affects *all supported versions of Novell GroupWise, the third-biggest corporate email software product which has a base of about 30 million users* according to Novell.

It could be argued that this is a vulnerability, and not a technique. Well, in reality it's both. The feature being forged is different to the usual CSRF payloads that most people are familiar with:

- adding a new administrative user (applies to admin consoles)
- changing the targeted user's password (would only work if the current password is NOT required to change to a new one)
- transferring money (applies to financial apps)

January 31, 2009 at 10:17 AM

MustLive said...



Adrian, yes it's possible to include this new research in current list.

It depends on position of the author. For example, yesterday I wrote article Enumerating logins via Abuse of Functionality vulnerabilities (<http://websecurity.com.ua/2840/>, which you can read on English <http://www.google.com/translate?u=http://websecurity.com.ua/2840/&langpair=ua%7Cen&hl=en&ie=UTF8>).

I made this research in March 2008, but because I published it this year, this article would be for 2009's hack techniques.

January 31, 2009 at 1:21 PM

Jeremiah Grossman said...



@Adrian, not to take anything away from the good research, but I don't think this qualifies as a new "technique." While there is some wiggle room for inclusion, I really wanted to stay away from a general list of vulnerabilities.

February 1, 2009 at 5:33 PM

Jeremiah Grossman said...



@Yair, Im on the edge on this one. Its cool stuff for sure, but can we consider this web-based? I'll probably take your word for it either way...what do you think?

February 1, 2009 at 5:35 PM

Anonymous said...

@Jer

I have sent my submission on your email id
jeremiah@whitehatsec.com

If it needs to be changed. Let me know.

February 3, 2009 at 7:19 PM

Anonymous said...

All part of the same attack:

http://www.secforce.co.uk/media/presentations/OWASP_Abusin_g_PHP_sockets.pdf

http://www.secforce.co.uk/media/tools/socket_attack.zip

http://www.secforce.co.uk/media/demos/PHP_socket_hijacking_demo.html

February 5, 2009 at 3:20 PM

Anonymous said...

SQL Smuggling

Released end of 2007, but publicized [this year](#) .

Also was a recent lecture at RSA Conference Europe...

February 8, 2009 at 10:30 AM

Jeremiah Grossman said...



Abusing PHP sockets added, as was SQL Smuggling and CSRF on Novell GroupWise WebAccess.

Thanks all, good work!

February 9, 2009 at 9:28 AM

Unknown said...



what about the CSS Attribute Reader?

Was paralelly discovered by Wisec and I (and I disclosed it on Microsoft Bluehat, and Wisec disclosed it on RuxCon), check out wisec's PoC:

<http://www.wisec.it/CssSteal/frame.html>

What that is doing, is reading from here:

<http://www.wisec.it/CssSteal/vulnNoScript.php>

The value of a hidden attribute:

input type='hidden' value='ap23_\$\$'

Without the use of javascript!! just pure CSS!! isnt that awesome??

It's a potential attack for XSS without JS (Cross Site Styling?)

References:

- <http://sirdarckcat.blogspot.com/2008/10/about-css->

attacks.html (checkout the last title about CSS attribute reader)

- http://www.yscx.net/root/documents/The_Sexy_Assassin.ppt

- <http://eaea.sirdarckcat.net/cssar/v2/?source>

-

http://www.ush.it/team/ascii/Attacking_Rich_Internet_Applications.ppt

February 15, 2009 at 11:36 PM

Unknown said...



Oh! and the CSSH! CSS Stealing Some History - Monitor!

The PoC:

<http://eaea.sirdarckcat.net/cssh-mon/cssh-mon.php>

What it does is it fetches all the websites you have visited, and the ones you "are" visiting.. so if for example, you go to www.w3.org and then on other tab you go to:

[http://eaea.sirdarckcat.net/cssh-mon/cssh-mon.php?](http://eaea.sirdarckcat.net/cssh-mon/cssh-mon.php?z-http%3A%2F%2Fwww.w3.org%2F)

[z-http%3A%2F%2Fwww.w3.org%2F](http://eaea.sirdarckcat.net/cssh-mon/cssh-mon.php?z-http%3A%2F%2Fwww.w3.org%2F)

Then you can navigate on [w3.org](http://www.w3.org) and the CSSH-MON will fetch all your navigation history (with the exact time you clicked each link).

The references are:

http://www.yscx.net/root/documents/The_Sexy_Assassin.ppt

<http://p42.us/css/>

February 16, 2009 at 10:38 AM

[Post a Comment](#)

[Newer Post](#)

[Home](#)

[Older Post](#)

Subscribe to: [Post Comments \(Atom\)](#)

Picture Window theme. Powered by Blogger.

This site uses cookies from Google to deliver its services and to analyse traffic. Your IP address and user agent are shared with Google, together with performance and security metrics, to ensure quality of service, generate usage statistics and to detect and address abuse.

[LEARN MORE](#) [GOT IT](#)